



REVUE DE MISE EN PRODUCTION — CONFIDENTIEL

Nimbus Notes

Revue par Hamdi Hadrich · 2026-08-05 · commit revu : 9d4c1e2

Nature de la revue. Revue heuristique par lecture. Ni audit de sécurité, ni test d'intrusion, ni garantie. Elle atteste le travail effectué et les points vérifiés — jamais que l'application « est sécurisée ».

Incident. clé fournisseur active trouvée dans l'historique — client prévenu 2026-08-05, révocation conseillée

Trois priorités

#	Point	À faire
1	Secrets	Révoquer la clé chez le fournisseur, pas seulement la supprimer ; purger l'historique ; ajouter un scan de secrets en pre-commit.
2	Auth des routes	Recenser les routes mutantes, puis exiger l'authentification sur celles qui ne sont pas publiques par conception (webhooks signés, inscription, connexion).
3	Sauvegardes	Faire une restauration test vers une instance jetable, jamais sur la production, puis la programmer trimestriellement.

Les dix points

Point	État	Constat	À faire
Secrets	RED	git history 4f1a9c — provider API key committed then removed (VALUE REDACTED)	voir priorité 1
Hygiène .env	AMBER	.env gitignored, mais pas de .env.example committé	Ajouter un .env.example documentant les variables attendues.
Auth des routes	RED	src/api/notes.ts:44 — DELETE /notes/:id sans vérification d'appelant	voir priorité 2
Base exposée	NOT_VERIFIABLE	La config montre l'app joignant la base par le réseau interne ; savoir si la base répond aussi depuis l'Internet public se lit dans la console du fournisseur, restée fermée pendant l'entretien. Noté invérifiable — le silence n'est jamais noté comme sain	Ouvrir l'onglet réseau de la console fournisseur : si la liste d'IP externe est vide ou absente, la fermer explicitement
Sauvegardes	RED	Sauvegardes configurées mais jamais restaurées	voir priorité 3
Disponibilité	AMBER	Endpoint /health existe, aucun ping externe	Ajouter une sonde de disponibilité externe qui alerte une personne.
Supervision erreurs	GREEN	Sentry câblé ; dernière erreur captée la semaine passée	—
Limitation de débit	AMBER	Throttle sur /login, absent sur les POST publics	Étendre la limitation de débit aux POST publics.
Dépendances	GREEN	package-lock.json présent, versions récentes	—
Garde-fous de coûts	RED	Aucune alerte de dépense sur le compte cloud	Poser une alerte budgétaire ; définir qui est prévenu à 10× le trafic.

Briefs d'investigation. Un brief par priorité à donner à votre agent IA — fichier joint *diligence-report-nimbus-notes-briefs.md*. Il produit un plan, jamais un correctif.

Attestation. Revue en lecture seule sur copie — aucun système en production n'a été touché, aucun défaut n'a été exploité. Aucune valeur de secret n'apparaît dans ce rapport (emplacements seulement). Copie du dépôt supprimée à la remise. Autorisation : email 2026-08-04, reply « d'accord » (dont le point 4, clause de responsabilité) — repo github.com/client/nimbus.